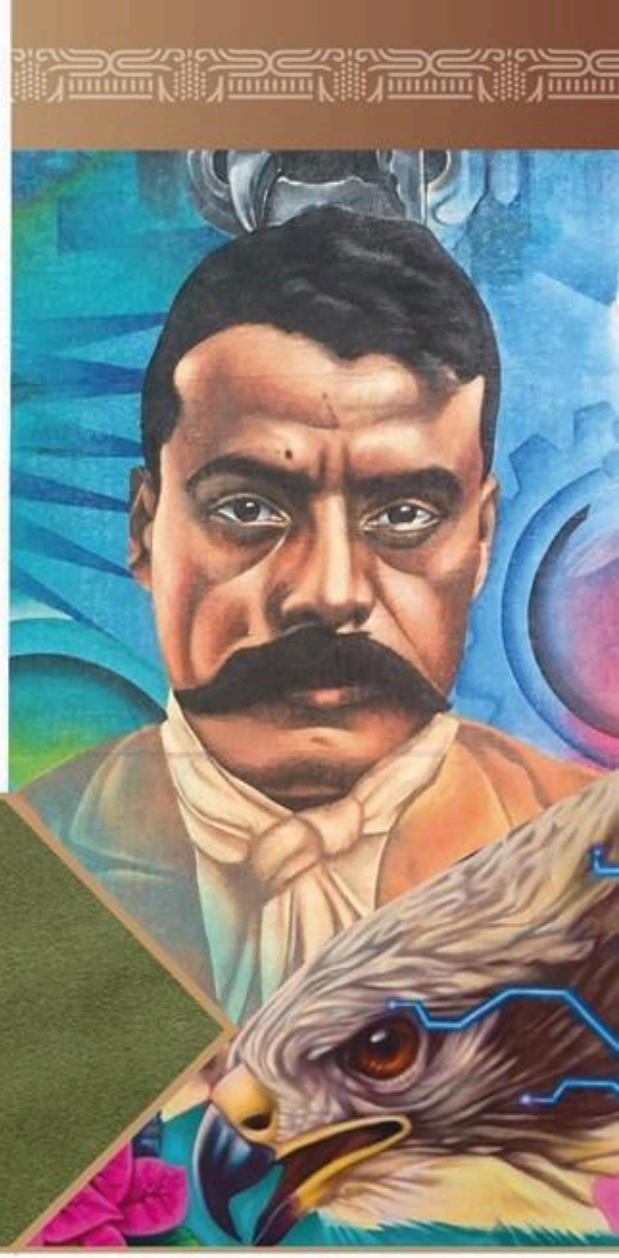
UNIVERSIDAD TECNOLÓGICA EMILIANO ZAPATA DEL ESTADO DE MORELOS

DIVISIÓN ACADÉMICA DE TECNOLOGÍAS DE LA INFORMACIÓN Y DISEÑO



REPORTE DE ESTADÍA

QUE PARA OBTENER EL GRADO DE:

PRUEBAS DE CUMPLIMIENTO Y ALINEACIÓN AL MARCO DE REFERENCIA

INGENIERÍA EN REDES INTELIGENTES Y CIBERSEGURIDAD

PLATAFORMA AUTÓNOMEDA

PRESENTA:

ROBBIE DANIEL MEJÍA ARROYO

ASESOR EMPRESARIAL

M.C. OMAR HERNÁNDEZ LÓPEZ

ASESORA UNIVERSITARIA

M.T.I. VERÓNICA SÁNCHEZ LÓPEZ

UTEZ
UNIVERSIDAD TECNOLÓGICA EMILIANO ZAPATA DEL ESTADO DE MORELOS

División Académica de Tecnologías de la Información y Diseño

EMILIANO ZAPATA, MOR., MAYO DE 2026

CONTENIDO

Índice de figuras
Índice de tablas
Agradecimientos
Resumen
Summary

CAPÍTULO 1. DESCRIPCIÓN DEL PROYECTO..... 8

1.1 Datos generales de la empresa..... 8

1.2 Antecedentes del proyecto..... 9

1.3 Objetivo general..... 10

1.4 Objetivos específicos..... 10

1.5 Justificación..... 10

1.6 Alcances..... 11

1.7 Restricciones..... 12

CAPÍTULO 2. MARCO DE REFERENCIA..... 13

2.1 Principios teóricos, metodologías y herramientas..... 13

2.1.1 Fundamentos de Seguridad en Aplicaciones Web..... 13

2.1.2 Marcos de Referencia y Metodologías de Pruebas de Seguridad..... 17

2.1.3 Herramientas para el Escaneo de Vulnerabilidades (DAST)..... 20

2.2 Propuesta de solución..... 23

2.2.1 Viabilidad del proyecto..... 24

CAPÍTULO 3. DESARROLLO..... 25

3.1 Inicio..... 25

3.1.1 Acta de Constitución del Proyecto (Project Charter)..... 25
3.2 Planeación..... 26
3.2.1 Metodología y Herramientas..... 27
3.2.2 Análisis de Riesgos del Proyecto..... 27
3.2.3 Cronograma de Actividades..... 28
3.3 Ejecución..... 30
3.3.1 Fase I: Investigación y Selección Metodológica..... 30
3.3.2 Fase II: Evaluación de Seguridad y Hallazgos (OWASP 2025)..... 30
3.3.3 Fase III: Propuesta de Mitigación (Recomendaciones)..... 41
3.3.4 Fase IV: Reevaluación y Resultados de Mitigación..... 46
3.4 Control..... 46
3.4.1 Reuniones de Seguimiento y Presentación de Avances..... 47
3.4.2 Seguimiento de Actividades..... 47
3.5 Cierre..... 48
3.5.1 Finalización y Entrega de Resultados..... 48
3.5.2 Relación de Entregables Técnicos..... 48
CAPÍTULO 4. CONCLUSIONES..... 50
4.1 Cumplimiento de objetivos..... 50
4.2 Resultados..... 50
4.3 Contribuciones..... 51

REFERENCIAS

ANEXOS

ÍNDICE DE FIGURAS

Figura 1.1 Logotipo de la empresa 8
Figura 1.2 Logotipo de la plataforma 9
Figura 3.1 Project Charter del proyecto Andrómeda 26
Figura 3.2 APIs expuestas 31
Figura 3.3 Accesos no autorizados 31
Figura 3.4 Ataque clickjacking 32
Figura 3.5 Evaluación de puertos con Nmap 33
Figura 3.6 Exposición del servidor desde OWASP ZAP 34
Figura 3.7 Analisis estatico con Horusec 36
Figura 3.8 Pruebas de ataques HTMLi y XSS básico 37
Figura 3.9 Análisis de seguridad en las cookies de sesión 38
Figura 3.10 Acceso denegado sin ninguna sesión 38
Figura 3.11 Validación estricta de archivos xlsx 40
Figura 3.12 Pruebas de fuzzing desde Burp Suite 41
Figura 3.13 Mensaje de error .NET 8 desde el login 43
Figura 3.14 Mensaje de error C# desde Andrómeda 43

ÍNDICE DE TABLAS

Tabla 3.1 Involucrados y sus funciones 25
Tabla 3.2 Matriz de Análisis Riesgos 28
Tabla 3.3 Cronograma de actividades 29
Tabla 3.4 Matriz de vulnerabilidades en componentes de terceros 35

AGRADECIMIENTOS

A mi mamá Eva y mi papá Hugo, por ser mi apoyo incondicional en cada etapa de mi formación. Gracias por su sacrificio, por creer siempre en mi capacidad y por darme los valores necesarios para alcanzar esta meta profesional. Todo mi esfuerzo es para ustedes.

A mi grupo de amigos, por estar presente en los momentos de estrés y por todas aquellas pláticas filosóficas que me ayudaron a despejar la mente.

A mi asesor, por otorgarme la confianza y la oportunidad de trabajar en este proyecto de seguridad.

Al Instituto Nacional de Electricidad y Energías Limpias (INEEL), por brindarme el espacio y las facilidades necesarias para realizar mis estadías profesionales. Gracias a todo el equipo de trabajo por su disposición y por permitirme aprender en un entorno real y de alta exigencia.

RESUMEN

Se detalló en el presente proyecto la auditoría de seguridad realizada a la plataforma de inteligencia empresarial "Andrómeda" dentro del Instituto Nacional de Electricidad y Energías Limpias (INEEL). La investigación se centró en identificar vulnerabilidades críticas bajo el estándar OWASP Top 10 versión 2025, utilizando una metodología híbrida que combinó el análisis estático de código fuente (SAST) con pruebas dinámicas de penetración (DAST). Mediante el uso de herramientas especializadas en un entorno BlackArch Linux, como Horusec, OWASP ZAP y Burp Suite, se detectaron brechas significativas en la gestión de credenciales, la configuración de servidores IIS y la cadena de suministro de software.

La intervención técnica permitió al INEEL fortalecer la postura de seguridad de la plataforma, logrando la mitigación de riesgos de inyección y exposición de secretos, asegurando así la confidencialidad de los modelos económicos estratégicos que el instituto gestiona. Este reporte no solo ofrece un diagnóstico profundo de la herramienta Andrómeda, sino que establece una hoja de ruta para el fortalecimiento de la seguridad de la información de los activos digitales institucionales.

En cuanto a la organización de este documento, el Capítulo 1 describe las generalidades y el contexto del INEEL; el Capítulo 2 expone el marco teórico y los conceptos fundamentales de ciberseguridad aplicados; el Capítulo 3 constituye el núcleo del reporte, detallando la planeación, ejecución técnica y las fases de control del proyecto; finalmente, el Capítulo 4 presenta las conclusiones y contribuciones obtenidas durante el periodo de estadías.

SUMMARY

This project was focused on the security audit performed on the "Andrómeda" business intelligence platform at the National Institute of Electricity and Clean Energies (INEEL). The research was centered on identifying critical vulnerabilities under the OWASP Top 10 2025 standard, using a hybrid methodology that combined static source code analysis (SAST) with dynamic penetration testing (DAST). By utilizing specialized tools in a BlackArch Linux environment—such as Horusec, OWASP ZAP, and Burp Suite—significant gaps were detected in credential management, IIS server configurations, and the software supply chain.

The technical intervention allowed INEEL to strengthen the platform's security posture, achieving the mitigation of injection risks and secrets exposure, thereby ensuring the confidentiality of the strategic economic models managed by the institute. This report not only offers a profound diagnosis of the Andromeda tool but also establishes a roadmap for strengthening the information security of the institutional digital assets.

Regarding the organization of this document, Chapter 1 describes the general background and context of INEEL; Chapter 2 presents the theoretical framework and fundamental cybersecurity concepts applied; Chapter 3 constitutes the core of the report, detailing the planning, technical execution, and control phases of the project; finally, Chapter 4 presents the conclusions and contributions obtained during the internship period.

CAPÍTULO 1. DESCRIPCIÓN DEL PROYECTO

1.1 Datos generales de la empresa

El Instituto Nacional de Electricidad y Energías Limpias (INEEL), es un centro de investigación del sector energía, dedicado principalmente a las áreas eléctrica y de energías limpias en México, cuya identidad institucional se presenta en la Figura 1.1.



Figura 1.1 Logotipo de la empresa

El INEEL se encuentra ubicada en Calle Reforma N° 113, Colonia Palmira, Cuernavaca, Morelos, México, C.P. 62490.

Es una organización que cuenta con un equipo multidisciplinario de investigadores y especialistas enfocados en el desarrollo tecnológico del sector energético.

Su estructura organizacional se divide en la Dirección General, Divisiones y Gerencias especializadas, destacando la Gerencia de Tecnologías de la Información y la perteneciente a la División de Tecnologías Habilitadoras, donde ingenieros con diversas especialidades, prestan servicios y desarrollan sistemas de información relacionados al sector energético y energías limpias en México.

Para la ejecución y validación técnica de las actividades, el proyecto desarrollado en esta institución, cuenta con la dirección del M.C Omar Hernández López, quien

desempeña el cargo de Investigador y funge como Asesor Empresarial en este proyecto.

1.2 Antecedentes del proyecto

La Coordinación de Estudios Económicos de la Comisión Federal de Electricidad (CFE) requiere de herramientas precisas para el modelado de escenarios y la generación de pronósticos que impactan en la planeación estratégica del sector energético nacional. Históricamente, este tipo de análisis demandaba procesos complejos de gestión de datos, lo que impulsó el desarrollo de la Plataforma Andrómeda por parte del INEEL. Esta solución ha sido diseñada como un sistema de Inteligencia Empresarial capaz de procesar volúmenes masivos de información para la toma de decisiones económicas.

Con la evolución de la plataforma y su integración en procesos críticos relacionados con el Mercado Eléctrico Mayorista (MEM), la seguridad de la información se convirtió en una prioridad institucional. El manejo de modelos econométricos y proyecciones financieras dentro de Andrómeda, representada por el logotipo Figura 1.2,implica el uso de datos sensibles cuya confidencialidad es vital para la soberanía tecnológica de la CFE. Sin embargo, el análisis preliminar de la infraestructura detectó áreas de oportunidad en la configuración del servidor web y en la integridad de las librerías de terceros utilizadas en el desarrollo.



Figura 1.2 Logotipo de la plataforma

Ante este panorama, surgió la necesidad de someter a la plataforma a un proceso de evaluación robusto sobre la vulnerabilidad de la información. El presente proyecto se origina como una respuesta técnica para alinear los componentes de Andrómeda con

los estándares internacionales de seguridad mediante el marco de referencia OWASP. De esta manera, el INEEL busca no solo validar la funcionalidad de la herramienta, sino garantizar una postura de ciberseguridad resiliente que proteja el código fuente y la información crítica contra vectores de ataque modernos, asegurando así un producto final confiable para la Comisión Federal de Electricidad.

1.3 Objetivo general

Fortalecer la seguridad de la información de la plataforma de inteligencia empresarial Andrómeda, mediante recomendaciones de acción resultantes de la ejecución de pruebas de penetración y la alineación con el marco de referencia OWASP, para mitigar vulnerabilidades que pongan en riesgo la integridad de los modelos de pronósticos económicos de la CFE.

1.4 Objetivos específicos

1. Ejecutar escaneos de vulnerabilidades dinámicos (DAST) utilizando OWASP ZAP para identificar fallas en la configuración de cabeceras y manejo de sesiones.
2. Analizar el tráfico de red mediante Burp Suite para validar la seguridad de las cookies (HttpOnly) y la exposición del tráfico no cifrado del servidor.
3. Auditar el código fuente en busca de secretos expuestos y credenciales hardcoded relacionadas con servicios de nube (AWS/Azure).
4. Evaluar la resiliencia del sistema ante entradas malformadas mediante pruebas de Fuzzing.
5. Elaborar una matriz de cumplimiento que clasifique los hallazgos por prioridad y complejidad de solución.

1.5 Justificación

La ejecución de este proyecto es fundamental debido a que la Plataforma Andrómeda constituye una herramienta estratégica de Inteligencia Empresarial para la Coordinación de Estudios Económicos de la CFE. Dado que el sistema procesa volúmenes masivos de datos para el modelado de escenarios y pronósticos financieros, cualquier vulnerabilidad en el software representa un riesgo directo para la confidencialidad de la planeación estratégica nacional de la CFE. La detección de riesgos críticos, como credenciales expuestas y componentes obsoletos, hace indispensable la adopción de un marco de seguridad que mitigue posibles exfiltraciones de información sensible.

Al alinear la plataforma con el estándar internacional OWASP, el INEEL garantiza la protección de la información, propiedad intelectual y el código fuente de los sistemas desarrollados, los cuales son activos exclusivos de la CFE según los acuerdos de confidencialidad vigentes. El beneficio institucional radica en la transición hacia un modelo de desarrollo seguro que permita la integridad de los modelos econométricos y la disponibilidad de los servicios frente a ciberataques sofisticados.

1.6 Alcances

El alcance del presente proyecto se delimita a la evaluación y recomendación técnica de la postura de seguridad de la plataforma Andrómeda, concentrándose específicamente en los módulos de integración y el servidor web. Las actividades programadas incluyen:

- **Identificación de vulnerabilidades:** Aplicación estricta del estándar internacional **OWASP Top 10** para la detección de fallas de seguridad.
- **Análisis Dinámico (DAST):** Ejecución de escaneos activos sobre la interfaz y APIs mediante herramientas como OWASP ZAP y Burp Suite.
- **Análisis Estático (SAST):** Revisión manual del código fuente para la detección de credenciales embebidas (hardcoded) y configuraciones inseguras.

- **Pruebas de Autenticación:** Validación de los mecanismos de control de acceso, gestión de sesiones y protección de cookies.
- **Documentación Técnica:** Entrega de una matriz de cumplimiento y una guía de mitigación con recomendaciones específicas para el equipo de desarrollo.

Por otra parte, el proyecto establece límites claros sobre las actividades no contempladas: **no se incluye la remediación de todos los hallazgos detectados** en el código fuente, labor que corresponde al equipo de programación del INEEL.

1.7 Restricciones

El desarrollo del proyecto está sujeto a restricciones operativas estrictas, donde las pruebas de seguridad se limitan exclusivamente a entornos de desarrollo para evitar cualquier impacto en la disponibilidad de los servicios de inteligencia empresarial de la plataforma Andrómeda. Se prohíbe el análisis sobre la infraestructura productiva o bases de datos reales de la CFE, centrando la evaluación en la capa de aplicación y servicios web bajo el estándar OWASP, sin incluir auditorías de red robustas, pruebas de infraestructura física ni ataques de denegación de servicio masivo.

La profundidad de las pruebas está delimitada cronológicamente por el periodo de la estadía profesional, estableciendo la conclusión de la documentación técnica y la entrega de la matriz de cumplimiento para el mes de abril de 2026.

CAPÍTULO 2. MARCO DE REFERENCIA

2.1 Principios teóricos, metodologías y herramientas

El desarrollo de este proyecto requiere el dominio de conceptos fundamentales orientados a la seguridad en aplicaciones web y la protección de datos en sistemas de Inteligencia Empresarial. Esta sección presenta el marco teórico, las metodologías de evaluación y las herramientas tecnológicas necesarias para asegurar la integridad de la plataforma Andrómeda durante su fase de implementación.

2.1.1 Fundamentos de Seguridad en Aplicaciones Web

La seguridad en aplicaciones de Inteligencia Empresarial (BI) como Andrómeda requiere comprender la arquitectura de red y la naturaleza de los datos que se transmiten. Dado que estos sistemas consolidan información estratégica de diversas fuentes para la toma de decisiones, su protección no solo implica blindar el perímetro, sino garantizar la integridad de los modelos analíticos y la privacidad de los tableros de control. En este contexto, la ciberseguridad se convierte en un habilitador crítico que previene la manipulación de datos y asegura que los activos de información del instituto permanezcan inalterados frente a accesos no autorizados o inyecciones de código malicioso en las capas de visualización y procesamiento. Bajo esta premisa, (SANS Institute, 2025) informa que la protección de sistemas de inteligencia de negocios debe priorizar el control de acceso granular y el cifrado de datos en tránsito, ya que los entornos de inteligencia empresarial representan objetivos de alto valor debido a la gran concentración de datos sensibles en un solo punto de acceso.

A continuación, se detallan los pilares técnicos fundamentales:

Modelo de Interconexión de Sistemas Abiertos (OSI) enfocado en la Capa 7

La seguridad de la información en plataformas de inteligencia empresarial requiere un análisis multidimensional que abarque desde la infraestructura de red hasta la lógica de la aplicación. En este contexto, la (Organización Internacional de Normalización (ISO), 1994) define el Modelo de Interconexión de Sistemas Abiertos (OSI) en el estándar ISO/IEC 7498-1 como la base funcional para la comunicación de datos. Para el presente proyecto, el enfoque se sitúa en la Capa 7 (Capa de Aplicación), nivel donde operan los protocolos con los que interactúa el usuario de la plataforma Andrómeda. La protección en este nivel es determinante, ya que es donde se manifiestan ataques de lógica de negocio e inyecciones que el marco OWASP busca mitigar.

Protocolo de Transferencia de Hipertexto Seguro (HTTPS)

Para asegurar la confidencialidad de los datos económicos gestionados, la implementación del Protocolo de Transferencia de Hipertexto Seguro (HTTPS) resulta indispensable. Según define la comunidad (Mozilla, 2025), este protocolo actúa como la versión protegida de HTTP, estableciendo un cifrado de extremo a extremo que previene ataques de escucha y suplantación de identidad entre el navegador y el servidor.

TLS (Transport Layer Security):

El documento RFC 8446 del (Grupo de trabajo de ingeniería de Internet (IETF), 2018) identifica al protocolo TLS 1.3 como el sucesor moderno de SSL, encargado de cifrar la transmisión, garantizar la integridad de los datos y autenticar a las partes mediante certificados digitales.

La comunicación entre el cliente y el modelo de inteligencia empresarial debe estar protegida mediante HTTPS. Este protocolo utiliza el cifrado TLS (Transport Layer Security) para establecer un canal seguro. Sus funciones principales son:

- Cifrado: Oculta los datos frente a observadores.
- Integridad: Garantiza que los datos no sean modificados durante el trayecto.
- Autenticación: Verifica, mediante certificados digitales, que el servidor es realmente quien dice ser.

Arquitectura de Aplicaciones Web y flujos de datos en Inteligencia Empresarial

Como lo señala (Sommerville, 2011), a diferencia de un sitio web estático, una plataforma de inteligencia empresarial (BI) tiene una arquitectura compleja que incluye el Frontend (donde se visualizan los tableros), el Backend (donde reside la lógica del modelo) y la Capa de Datos (Data Warehouse).

La seguridad debe aplicarse en cada flujo: desde la petición del usuario hasta la consulta a la base de datos, asegurando que la información estratégica del instituto no sea expuesta en ninguna etapa del procesamiento.

Triada de la Seguridad de la Información: Confidencialidad, Integridad y Disponibilidad

Este es el modelo diseñado por el (Instituto Nacional de Estandares y Tecnologías (NIST), 2004) para guiar las políticas de seguridad de cualquier organización. En el contexto de la plataforma Andrómeda se define como:

- **Confidencialidad**: Representa el primer nivel de protección dentro del modelo de inteligencia empresarial, actuando como un blindaje que impide la divulgación no autorizada de la información estratégica del instituto. En el contexto de un sistema de BI, esto implica la implementación de controles de acceso estrictos y mecanismos de cifrado robustos que aseguren que los tableros de control y los modelos analíticos sean visibles únicamente para los perfiles de usuario previamente validados. La gestión de la confidencialidad se extiende al manejo de las credenciales y la segmentación de datos, evitando que vulnerabilidades como el control de acceso quebrado permitan a un tercero interceptar reportes financieros o técnicos que son propiedad intelectual del INEEL.
- **Integridad**: Se define como la garantía de que la información y los procesos de cálculo de la plataforma Andrómeda permanecen inalterados desde su origen hasta su visualización final. En un entorno de BI, la integridad es crítica, ya que una modificación malintencionada en los parámetros de entrada o en los algoritmos del modelo podría derivar en reportes erróneos, induciendo a los tomadores de decisiones a ejecutar acciones basadas en datos falsos. Mantener la integridad requiere validar que no existan vectores de inyección o fallos de configuración que permitan a un atacante manipular las bases de datos o el código fuente de la aplicación, asegurando así que el flujo de información sea veraz, completo y confiable en todo momento.
- **Disponibilidad**: Asegura que la infraestructura tecnológica y los datos de la plataforma estén siempre operativos y accesibles para los usuarios autorizados cuando el proceso de negocio lo demande. Esto implica que la plataforma debe poseer la capacidad de resistir ataques de denegación de servicio o fallos técnicos que pretendan interrumpir el flujo de inteligencia empresarial. En el INEEL, la disponibilidad es fundamental para la continuidad operativa, por lo que la auditoría de seguridad busca identificar puntos críticos de falla que pudieran dejar fuera de línea los servicios analíticos, garantizando que el sistema sea resiliente ante cargas de trabajo elevadas o intentos de intrusión que busquen degradar el rendimiento de los servidores donde se aloja Andrómeda.

2.1.2 Marcos de Referencia y Metodologías de Pruebas de Seguridad

Los marcos de referencia y las metodologías de pruebas de seguridad constituyen la base estructurada para evaluar y fortalecer la protección de los sistemas de información. A través de lineamientos, estándares y buenas prácticas, estos enfoques permiten identificar vulnerabilidades, analizar riesgos y validar la eficacia de los controles de seguridad implementados. Su aplicación sistemática no solo facilita la detección de posibles fallas, sino que también garantiza que las pruebas se realicen de manera ordenada, repetible y alineada con objetivos organizacionales y normativas vigentes. De esta forma, los marcos y metodologías se convierten en herramientas esenciales para asegurar la integridad, confidencialidad y disponibilidad de la información en entornos digitales cada vez más complejos.

OWASP Top 10.

Complementando la arquitectura de red, la metodología de evaluación en este proyecto, se fundamenta en los estándares de la (OWASP, 2025), (Open Web Application Security Project) es una organización internacional sin fines de lucro que mejora la seguridad del software, ofreciendo recursos gratuitos como documentación, herramientas (ej., OWASP ZAP) y guías (ej., OWASP Top 10) para desarrollar aplicaciones web más seguras, operando como una comunidad abierta global para educar y colaborar en la prevención de vulnerabilidades.

Su documento primordial, el (OWASP Top 10, 2025), representa el consenso global sobre los riesgos más críticos para las aplicaciones web en la actualidad. La alineación de la plataforma Andrómeda con esta lista permite identificar vulnerabilidades prioritarias y establecer controles preventivos eficaces. Representa un amplio consenso sobre los riesgos de seguridad críticos para las aplicaciones web en el año 2025, los cuales son los siguientes:

1. Control de Acceso Roto: Riesgo de que el sistema omita la validación de permisos, permitiendo potencialmente el acceso a recursos restringidos.

2. Configuración de Seguridad Incorrecta: Usar configuraciones por defecto, servicios innecesarios activos o mostrar mensajes de error con detalles técnicos.

3. Fallas en la Cadena de Suministro: Confiar en librerías o dependencias de terceros que tienen vulnerabilidades o han sido "envenenadas" por hackers.

4. Fallas Criptográficas: No cifrar datos sensibles o usar algoritmos de cifrado viejos que ya son fáciles de romper.

5. Inyección: La aplicación envía datos del usuario a un intérprete (SQL, LDAP, SO) sin filtrarlos, y estos se ejecutan como comandos.

6. Diseño Inseguro: Es un error en los planos de la aplicación. Aunque el código esté bien escrito, el diseño permite acciones peligrosas porque no se pensó en la seguridad desde la etapa de planeación.

7. Fallas de Autenticación: Permitir ataques de fuerza bruta, no tener autenticación de dos factores (MFA) o permitir contraseñas débiles.

8. Fallas de Integridad: Descargar actualizaciones de software sin verificar su origen o procesar datos que no se sabe si fueron modificados.

9. Fallas en Registro y Alertas: No guardar logs (registros) de eventos importantes o no tener alertas que avisen si algo raro pasa.

10. Mal manejo de condiciones excepcionales: Cuando el software falla, revela información sensible o se queda en un estado inseguro (ej. el login falla, pero los fallos en el manejo de errores durante la autenticación permitan el acceso involuntario del usuario al sistema).

OSSTMM (Open-Source Security Testing Methodology Manual).

La auditoría de sistemas de información se rige bajo marcos metodológicos de alta rigurosidad. El Manual de la Metodología Abierta de Testeo de Seguridad (OSSTMM), desarrollado por (Herzog, 2003), aporta un enfoque científico basado en

la medición operativa de la seguridad, yendo más allá de los fallos comunes. A diferencia de otras metodologías que se centran solo en fallos comunes, el OSSTMM se basa en la medición operativa de la seguridad, algunas características son las siguientes:

- **Enfoque:** Se centra en la verificación de "controles" y en cómo estos protegen los activos. No solo busca vulnerabilidades, sino que mide el nivel de protección real.
- **Métrica Principal (RAV)**: Utiliza una métrica llamada Relative Asking Value (Valor de Evaluación de Riesgo), que otorga una puntuación numérica a la seguridad operativa, permitiendo comparar el estado de la plataforma en diferentes periodos de tiempo.
- **Canales de Seguridad**: Divide la auditoría en cinco canales: Seguridad de la Información, Seguridad de Procesos, Seguridad de Tecnologías de Internet, Seguridad de Comunicaciones y Seguridad Física.
- **Aplicación en Andrómeda**: Sería útil si el INEEL necesitara una certificación numérica exacta del nivel de blindaje de los modelos de inteligencia empresarial ante ataques externos.

NIST SP 800-115 (Technical Guide to Information Security Testing and Assessment).

El NIST (Instituto Nacional de Estándares y Tecnología) es una agencia del gobierno de los Estados Unidos que funge como el estándar técnico por excelencia a nivel mundial en materia de ciberseguridad.

La Guía NIST SP 800-115, publicada por (Scarfone, 2008), la cual se establece como el estándar técnico por excelencia para la planificación y ejecución de pruebas de seguridad en instituciones de alta formalidad y sus elementos principales son los siguientes:

- **Enfoque**: Proporciona un marco estructurado para planificar y ejecutar pruebas de seguridad. Se divide en cuatro fases principales: Planificación, Descubrimiento, Ejecución y Post-ejecución (Reporte).
- **Técnicas Clave**: Define procedimientos específicos para el escaneo de vulnerabilidades, pruebas de penetración, revisión de archivos de registro (logs) y revisión de configuraciones.
- **Mentalidad de Riesgo**: Está muy alineado con la gestión de riesgos organizacional. Su objetivo no es solo encontrar fallos, sino ayudar a la organización a entender el impacto de esos fallos en sus procesos de negocio.
- **Aplicación en Andrómeda**: Al ser el INEEL una institución ligada a normativas oficiales, el marco del NIST es ideal para asegurar que el proceso de auditoría siga un orden administrativo y técnico impecable.

2.1.3 Herramientas para el Escaneo de Vulnerabilidades (DAST)

El análisis dinámico requiere un conjunto de herramientas especializadas para interactuar con la plataforma y detectar fallos en tiempo de ejecución. En este proyecto, todas las herramientas se gestionan bajo el entorno de BlackArch Linux, un repositorio de expansión para Arch Linux que proporciona una infraestructura optimizada para pruebas de penetración y auditoría de seguridad.

OWASP ZAP (Zed Attack Proxy)

Constituye la piedra angular de este proyecto debido a su naturaleza de código abierto y su diseño específico para la seguridad de aplicaciones web. De acuerdo con la documentación oficial del proyecto ZAP (OWASP Foundation, 2010), esta herramienta opera bajo una arquitectura de proxy inverso que se sitúa entre el navegador del auditor y el servidor donde reside la plataforma Andrómeda, permitiendo una visibilidad total de las peticiones y respuestas HTTP/HTTPS.

Su motor de rastreo, conocido como Spidering, es capaz de indexar cada recurso del modelo de inteligencia empresarial, incluyendo aquellos que dependen de tecnologías modernas de JavaScript mediante su módulo AJAX Spider, el cual utiliza navegadores reales en segundo plano para descubrir eventos dinámicos. Además, cuenta con un potente sistema de escaneo activo que inyecta vectores de ataque diseñados para detectar fallas críticas como inyecciones SQL o Cross-Site Scripting (XSS). La versatilidad de ZAP se extiende a su capacidad de Fuzzing, donde se envían ráfagas de datos no estructurados a los puntos de entrada de la aplicación para identificar comportamientos inesperados del sistema, mientras que su sistema de alertas clasifica los riesgos por niveles de severidad técnica, facilitando la priorización de las mitigaciones dentro del ecosistema de inteligencia de negocios.

Burp Suite Community

Es reconocida globalmente como la plataforma líder para la auditoría manual de seguridad web, desarrollada por (PortSwigger, 2006) para proporcionar un control granular sobre cada bit de datos intercambiado. Su componente más utilizado es el Repeater, una herramienta que permite al auditor tomar una petición capturada desde los tableros de Andrómeda, modificar sus parámetros manualmente y reenviarla al servidor de forma iterativa para observar cambios en la lógica de respuesta, lo cual es vital para identificar vulnerabilidades de control de acceso. Asimismo, incluye el módulo Decoder, capaz de procesar múltiples capas de codificación como Base64, URL o Hexadecimal de manera instantánea, permitiendo revelar información sensible oculta en cookies o tokens de sesión. Aunque la versión Community (PortSwigger, 2024) no incluye el escáner automatizado de la versión Pro, compensa esta carencia con herramientas como el Comparer, que permite realizar un análisis diferencial bit a bit entre dos respuestas del servidor para detectar variaciones mínimas que podrían indicar una fuga de datos o una respuesta de error informativa que un atacante podría explotar para enumerar usuarios.

Horusec

Es una herramienta de código abierto desarrollada por (Zup Innovation, 2020), especializada en el Análisis Estático de Seguridad de Aplicaciones (SAST), que permite identificar vulnerabilidades directamente en el código fuente antes de que la aplicación sea desplegada. Su funcionamiento se basa en un orquestador de diversos motores de seguridad que escanean el repositorio en busca de patrones de código inseguro, configuraciones erróneas y brechas de seguridad lógica.

En la auditoría de la plataforma Andrómeda, Horusec desempeña un papel crítico al evaluar la integridad de la cadena de suministro y la gestión de secretos. Esta herramienta es fundamental para detectar fallas alineadas al OWASP A04:2021 (Fallas Criptográficas), permitiendo localizar credenciales de bases de datos y llaves de servicios de nube (AWS y Azure) que se encontraban embebidas (hardcoded) en el código. Además, su capacidad de análisis multilenguaje facilitó la detección de componentes obsoletos vinculados al OWASP A03:2021, como librerías de terceros con vulnerabilidades conocidas. La integración de Horusec en el proceso de evaluación asegura que la plataforma de inteligencia empresarial no solo sea resistente a ataques externos, sino que su base de código cumpla con los estándares de higiene criptográfica y desarrollo seguro desde su arquitectura interna.

Nmap (Network Mapper)

Nmap, se establece como la herramienta definitiva de reconocimiento y exploración de red dentro de la estación de trabajo BlackArch. En el contexto de un análisis DAST, según en la guía oficial (Lyon, 1997), Nmap se utiliza para definir la superficie de ataque inicial mediante la identificación precisa de los puertos abiertos y la versión exacta de los servicios que interactúan con la plataforma Andrómeda. Su potencia reside en el Nmap Scripting Engine (NSE), una arquitectura basada en el lenguaje Lua que permite automatizar tareas de detección de vulnerabilidades complejas,

como la comprobación de debilidades en el protocolo TLS o la búsqueda de archivos sensibles expuestos en el servidor web. Además, Nmap implementa técnicas sofisticadas de fingerprinting para determinar el sistema operativo del servidor con un alto grado de certeza, lo que permite al auditor enfocar sus esfuerzos en vulnerabilidades específicas de esa plataforma. Su capacidad de realizar escaneos silenciosos minimiza la carga sobre la red del INEEL, permitiendo obtener un mapa detallado de la infraestructura de soporte sin interferir con el tráfico legítimo de los modelos de inteligencia empresarial.

2.2 Propuesta de solución

Como medio de solución a los riesgos de seguridad identificados en la plataforma de inteligencia empresarial Andrómeda, se realizará una auditoría de pentesting web que permita analizar la robustez de los modelos analíticos y la infraestructura que los soporta. Se implementará la metodología OWASP Top 10 como marco de referencia para la ejecución del pentesting de manera sistemática, utilizando como base las fases teóricas detalladas en el apartado 2.1.2. Para esta auditoría, se empleará una estación de trabajo basada en Arch Linux, aprovechando el ecosistema de BlackArch para garantizar la precisión de las herramientas.

En la etapa de descubrimiento y planeación, se define el alcance técnico de la plataforma Andrómeda, incluyendo los módulos de visualización de datos, servicios de backend y los puntos de conexión con las fuentes de datos empresariales. Se establecerá un entorno de pruebas controlado para no afectar la disponibilidad de la inteligencia de negocios del instituto durante la fase activa.

Para la configuración del entorno de pruebas, se utilizan las herramientas DAST fundamentadas en la sección 2.1.3. Se empleará OWASP ZAP y Burp Suite Community para la intercepción y análisis de tráfico HTTP/HTTPS, permitiendo la identificación de fallas en la gestión de sesiones y control de acceso. Asimismo, se utilizará Nmap con scripts avanzados para mapear la superficie de ataque del

servidor y detectar servicios vulnerables que pudieran comprometer la integridad de los modelos de datos.

Durante la ejecución de pruebas, se lleva a cabo un análisis dinámico exhaustivo. Se interceptarán y manipularán las peticiones hacia las APIs de Andrómeda para evaluar la resistencia contra ataques de inyección y exposición de datos sensibles. Este proceso se complementará con un escaneo automatizado para detectar vulnerabilidades de configuración en el servidor web, asegurando que la arquitectura de BI sea resiliente ante vectores de intrusión modernos.

Se documentarán todos los hallazgos mediante un reporte técnico detallado, registrando las vulnerabilidades encontradas, clasificándolas por su nivel de impacto y proporcionando evidencias (logs y capturas) obtenidas durante su proceso. Se elaborarán recomendaciones técnicas específicas de mitigación, orientadas a fortalecer el ciclo de vida de desarrollo de la plataforma.

2.2.1 Viabilidad del proyecto

La viabilidad del proyecto es alta debido a los siguientes factores:

Viabilidad Técnica: Se cuenta con una estación de trabajo optimizada con Arch Linux y acceso a herramientas de auditoría de vanguardia en el repositorio BlackArch.

Viabilidad Económica: El uso de metodologías abiertas (OWASP) y herramientas de software libre (ZAP, Nmap) elimina costos de licenciamiento, permitiendo una auditoria profesional con recursos optimizados.

Viabilidad Operativa: Al realizarse en un entorno de preproducción, el análisis no interrumpe los procesos estratégicos del INEEL, permitiendo una remediación preventiva antes del despliegue final de Andrómeda.

CAPÍTULO 3. DESARROLLO

3.1 Inicio

El proyecto de evaluación de seguridad de la plataforma Andrómeda inició formalmente el 19 de enero de 2026. En la reunión de apertura con el M.C. Omar Hernández López, se realizó una inducción técnica sobre la arquitectura de la herramienta, la cual funciona como un sistema de Inteligencia Empresarial (BI) para la gestión de datos críticos del sector energético. Durante esta sesión, se definieron los roles de trabajo, donde el estudiante funge como Administrador del Proyecto y el asesor empresarial como el responsable de la validación técnica y operativa. La Tabla 3.1 Involucrados y sus funciones, describe a los involucrados y sus funciones.

Tabla 3.1 Involucrados y sus funciones

INVOLUCRADOS EN EL PROYECTO	
Nombre de la persona	**Función**
M.T.I Verónica Sánchez López	Sponsor *Externo*
M.C Liliana Paz Argotte Ramos	Cliente *Interno*
M.C Omar Hernández López	Asesor *Interno*
Robbie Daniel Mejía Arroyo	Administrador del proyecto *Interno*

3.1.1 Acta de Constitución del Proyecto (Project Charter)

Para formalizar el inicio del proyecto, se elaboró el acta de constitución del proyecto (Project Charter), el cual se muestra en la Figura 3.1 Project Charter del proyecto

Andrómeda y el documento se puede consultar en el Anexo A, documento que establece los objetivos, el alcance y los interesados clave. En este apartado se definieron como entregables principales la matriz de cumplimiento OWASP y el reporte de vulnerabilidades.

Aunque no se identificó un cliente externo directo, la División de Tecnologías Habilitadoras del INEEL actúa como la entidad patrocinadora (Sponsor), asegurando los recursos necesarios para la auditoría.

Project Charter

Proyecto	PCAMDO	Pruebas de cumplimiento y alineación al marco de referencia de desarrollo seguro OWASP en la plataforma Andrómeda.
Cliente		M.C Liliana Paz Argotte Ramos

Planteamiento del Problema
La plataforma Andrómeda, desarrollada por el INEEL para la CFE, es una herramienta de Inteligencia Empresarial (BI) crítica que maneja modelos de escenarios y pronósticos económicos nacionales. A pesar de su robustez funcional, el sistema carece de una evaluación de seguridad formal bajo estándares internacionales. Durante las fases de prueba preliminares, se han detectado riesgos de alta prioridad, como credenciales de servicios de nube (AWS/Azure) expuestas en el código y el uso de librerías obsoletas, lo que vulnera la integridad de la información estratégica de la CFE.

Justificación
La ejecución de este proyecto es indispensable para garantizar la propiedad intelectual y la confidencialidad de los datos del sector energético. La alineación con el estándar OWASP permite al INEEL realizar la transición de sistemas hacia un modelo de desarrollo seguro, mitigando vectores de ataque antes de la puesta en producción. Agregar seguridad al sistema Andrómeda no es solo una mejora técnica, sino un requisito de cumplimiento para proteger la toma de decisiones económicas de la Comisión Federal de Electricidad.

Objetivo General
Evaluar y fortalecer la postura de ciberseguridad de la plataforma Andrómeda mediante ejecución de pruebas de hacking ético alineadas al OWASP Top 10.

Entregables
Matriz de Cumplimiento OWASP.
Reporte de Vulnerabilidades SAST/DAST.
Guía de Mitigación y Buenas Prácticas.
Reporte Final de Estadía.

Figura 3.1 Project Charter del proyecto Andrómeda

3.2 Planeación

La fase de planeación permitió establecer la hoja de ruta técnica y operativa para la auditoría de la plataforma Andrómeda. En esta etapa se definieron no solo las

herramientas, sino también los tiempos, los riesgos y los mecanismos de acceso a la infraestructura de desarrollo del INEEL.

3.2.1 Metodología y Herramientas

Se seleccionó un enfoque de auditoría híbrido que combina el análisis de caja blanca y caja gris. Para la ejecución, se configuró un entorno de trabajo especializado basado en la distribución BlackArch Linux, integrando herramientas como Horusec para el análisis estático (SAST), OWASP ZAP y Burp Suite para el análisis dinámico (DAST), y Dependency-check para la identificación de librerías vulnerables. Este conjunto de herramientas permite una cobertura integral sobre los vectores de ataque definidos en el estándar OWASP.

3.2.2 Análisis de Riesgos del Proyecto

Se identificaron factores críticos que podrían impactar la continuidad de la auditoría. El riesgo técnico de mayor relevancia es la saturación accidental del Firewall o el servidor de aplicaciones derivado de la ejecución de pruebas de alta concurrencia (Fuzzing). Como medida de mitigación, se establecieron políticas de limitación de tráfico en las herramientas de escaneo y se acordó realizar las pruebas intensivas en horarios de baja carga para no afectar la operatividad del equipo de desarrollo del INEEL.

Otro riesgo detectado es la disponibilidad de la herramienta Andrómeda en su servidor de desarrollo y el acceso a internet, por lo que para mitigar el riesgo se instaló la herramienta en un ambiente local y las pruebas dinámicas se realizaron en el servidor de desarrollo. En la Tabla 3.2 se presentan los riesgos de manera resumida y en Anexo B.

Tabla 3.2 Matriz de Análisis Riesgos

ID	Riesgo Identificado	Descripción	Impacto	Probabilidad	Nivel de Riesgo	Medidas de Mitigación
R1	Saturación del firewall o servidor	Posible sobrecarga del firewall o del servidor de aplicaciones debido a pruebas de alta concurrencia (fuzzing).	Alto	Media	Alto	Limitación de tráfico en herramientas de escaneo y pruebas en horarios de baja carga.
R2	Indisponibilidad de la herramienta Andrómeda	Riesgo de no contar con acceso a la herramienta en el servidor de desarrollo o fallas en la conectividad a internet.	Medio	Media	Medio	Instalación en entorno local y pruebas dinámicas en el servidor de desarrollo.

3.2.3 Cronograma de Actividades

La ejecución del proyecto se estructuró en cinco fases fundamentales, distribuidas estratégicamente a lo largo del periodo comprendido entre enero y abril de 2026. Esta organización temporal, visualizada mediante un Diagrama de Gantt, presentado en la Tabla 3.3 y el cronograma completo se puede consultar en el Anexo B, asegura el cumplimiento de los hitos técnicos y administrativos bajo un enfoque de gestión de proyectos de ciberseguridad, las fases del proyecto se describen a continuación:

- **Fase 1.** Participar en sesiones de introducción a la plataforma Andrómeda y revisión del marco OWASP top 10: Esta etapa inicial se centró en la definición del marco de trabajo. Se realizaron las reuniones de apertura con el asesor empresarial para el reconocimiento de la arquitectura de la plataforma Andrómeda.
- **Fase 2.** Identificar riesgos de seguridad en módulos críticos de la plataforma Andrómeda: Durante este periodo se ejecutó el análisis de caja blanca. Se integró la herramienta Horusec para realizar el escaneo del código fuente en busca de vulnerabilidades lógicas y configuraciones inseguras.

- **Fase 3.** Establecer recomendaciones sobre vulnerabilidades identificadas: Se emplearon herramientas como OWASP ZAP, Burp Suite y Dependency-check para evaluar la plataforma en tiempo de ejecución, identificando fallas en la gestión de sesiones, componentes desactualizados y vulnerabilidades.
- **Fase 4.** Elaborar plan de pruebas sobre las recomendaciones realizadas: Se establecieron mecanismos de supervisión y seguimiento mediante reuniones periódicas con el equipo de desarrollo del INEEL.
- **Fase 5.** La fase final contempla la entrega de los resultados definitivos y la validación de las correcciones implementadas. Se formaliza la entrega de la matriz de cumplimiento OWASP y la documentación técnica de mitigación.

Tabla 3.3 Cronograma de actividades

Actividad	Meses del año 2026																			
	enero				febrero				marzo				abril				mayo			
1. Participar en sesiones de introducción a la plataforma Andrómeda y revisión del marco OWASP top 10.			■	■	■	■														
2. Identificar riesgos de seguridad en módulos críticos de la plataforma Andrómeda.					■	■	■	■	■											
3. Establecer recomendaciones sobre vulnerabilidades identificadas.									■	■	■	■	■							
4. Elaborar plan de pruebas sobre las recomendaciones realizadas.													■	■	■	■	■			
5. Documentación.					■	■			■	■			■	■			■	■	■	

3.3 Ejecución

La fase de ejecución constituye el núcleo técnico del proyecto, donde se sometió a la plataforma Andrómeda a un proceso de auditoría integral. Esta etapa se dividió en fases secuenciales que permitieron transformar la investigación teórica en hallazgos accionables y soluciones técnicas.

3.3.1 Fase I: Investigación y Selección Metodológica

La ejecución inició con una fase de reconocimiento y alineación estratégica. Se realizó una investigación profunda sobre el OWASP Top 10 versión 2025 para identificar cómo sus categorías de riesgo impactan específicamente en sistemas de Inteligencia Empresarial (BI) desarrollados en entornos .NET.

Para evaluar Andrómeda, se definió una estrategia de análisis progresivo que permitió identificar vulnerabilidades tanto en el código fuente (estático) como en el comportamiento del servidor (dinámico). A través de una fase de exploración basada en el estándar OWASP, se investigaron y seleccionaron herramientas de grado profesional conforme se detectaban necesidades específicas en el sistema. Esto llevó a la implementación de orquestadores de seguridad para la búsqueda de secretos, escáneres de interceptación de tráfico para la manipulación de cabeceras y utilerías de validación de dependencias. Este enfoque de investigación aplicada garantizó que cada categoría del Top 10 se validara mediante un método técnico específico, asegurando una cobertura integral de la superficie de ataque de la aplicación.

3.3.2 Fase II: Evaluación de Seguridad y Hallazgos (OWASP 2025)

Se realizaron las pruebas de penetración, documentando el estado de cumplimiento de la plataforma frente a cada riesgo del estándar:

A01 Control de Acceso Roto – [Estatus: No Cumple]:

Mediante el uso de Burp Suite y pruebas de interceptación de tráfico, se identificó que diversas APIs de la plataforma se encuentran expuestas y son accesibles mediante peticiones directas como se muestra en la Figura 3.2 APIs expuestas. Se confirmó que el sistema permite el consumo de estos recursos sin requerir un token de sesión válido o una autenticación previa, lo que facilita el acceso no autorizado a los endpoints de datos.

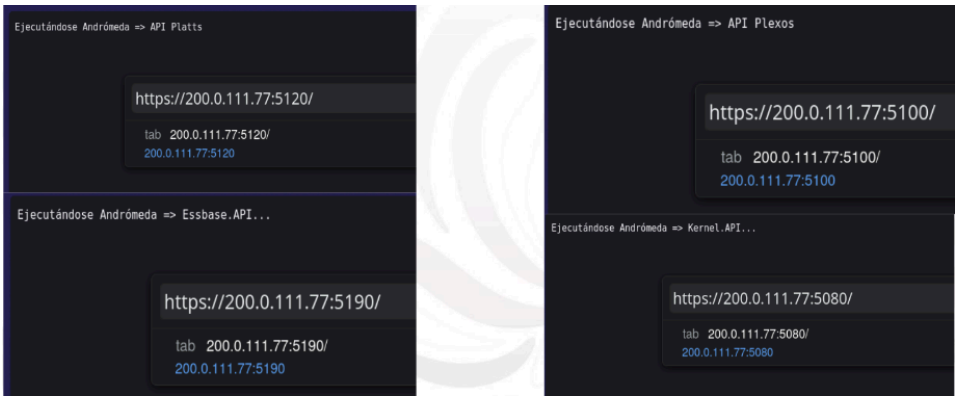


Figura 3.2 APIs expuestas

No obstante, en las pruebas de nivel de aplicación, se validó que el sistema cuenta con controles de acceso autorizados para los roles de usuario. Al iniciar sesión con el perfil "Emisiones" e intentar acceder a módulos restringidos exclusivos del perfil "Demanda", el sistema arrojó alertas de denegación de acceso como se muestra en la Figura 3.3 Accesos no autorizados.

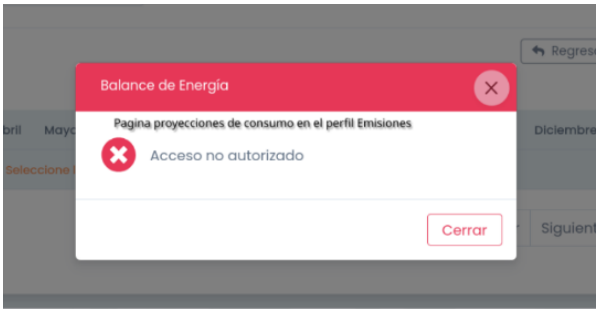


Figura 3.3 Accesos no autorizados

A02 Configuración Incorrecta – [Estatus: No Cumple]:

Se detectó la ausencia del encabezado de seguridad Content Security Policy (CSP). Esta omisión es crítica, ya que dicho encabezado es el encargado de restringir qué recursos pueden cargarse en el sitio, actuando como una barrera contra la ejecución de scripts maliciosos y la manipulación de la interfaz.

Como prueba de concepto, se realizó un ataque de Clickjacking exitoso, logrando embeber la plataforma Andrómeda dentro de un marco invisible (iframe) mostrado en la Figura 3.4 Ataque clickjacking. Debido a la falta de políticas de seguridad en las cabeceras, un atacante podría engañar a los usuarios para que realicen acciones involuntarias sobre la plataforma desde un sitio malicioso externo.



Figura 3.4 Ataque clickjacking

En cuanto a la infraestructura de red, la evaluación con Nmap reveló la exposición de los puertos 1433 y 5432, correspondientes a los motores de bases de datos SQL Server y PostgreSQL. La presencia de ambos puertos confirma la coexistencia de múltiples sistemas de almacenamiento, lo cual permite a un atacante inyectar código SQL específico contra la sintaxis de cada motor al identificar los puertos abiertos, el resultado de la prueba se visualiza en la Figura 3.5 Evaluación de puertos con Nmap. Asimismo, se identificó el puerto 445 activo, vinculado al protocolo SMB y asociado históricamente a vulnerabilidades de ejecución remota de código como WannaCry, lo que representa un riesgo de compromiso total del servidor.

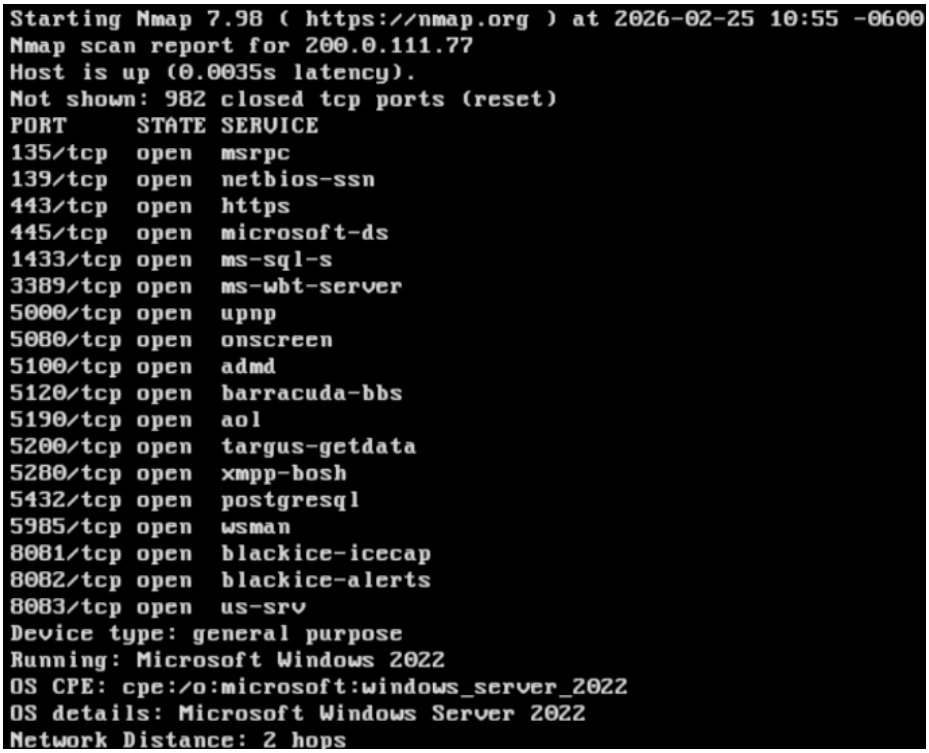


Figura 3.5 Evaluación de puertos con Nmap

Respecto al manejo de excepciones, se identificaron mensajes de error detallados como "Object reference not set to an instance of an object" y "Sequence contains no elements". Esta fuga de información confirmó que el sistema está desarrollado bajo el ecosistema .NET y C#. Para un atacante, esto funciona como un proceso de fingerprinting técnico, permitiéndole descartar vectores de ataque orientados a otros lenguajes (como PHP o Java) y concentrar sus esfuerzos en romper la lógica específica del servidor .NET.

La exposición de stack traces en los banners de error evidencia que el sistema no posee un manejador de excepciones genérico para el entorno de producción. Al ocurrir un fallo lógico, el backend envía al cliente la ruta completa del error y el rastro de la ejecución, revelando la estructura de directorios y funciones internas. Finalmente, mediante el tráfico capturado con OWASP ZAP, se identificó el banner

del servidor web IIS 10.0 desde el tráfico IP analizado y el resultado se puede observar en la Figura 3.6 Exposición del servidor desde OWASP ZAP.

Esta exposición permite la búsqueda directa de vulnerabilidades y exposiciones comunes específicas para dicha versión de Windows Server, optimizando el tiempo de reconocimiento del atacante.

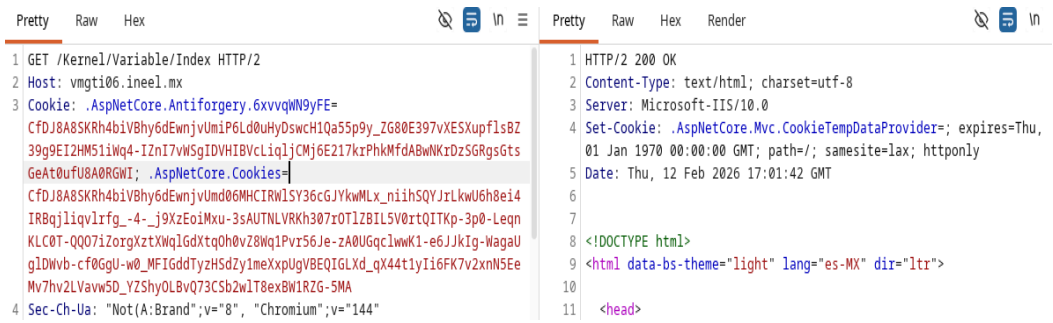


Figura 3.6 Exposición del servidor desde OWASP ZAP

A03 Fallas en Cadena de Suministro – [Estatus: No Cumple]:

A través de la herramienta Dependency-check, se identificó el uso de tres librerías críticas en versiones obsoletas: pdfmake 0.1.5, jQuery Validation 1.17.0 y Lodash. El uso de estos componentes desactualizados evidencia una debilidad en la gestión de la cadena de suministro de software, al incorporar dependencias con vulnerabilidades conocidas que pueden ser aprovechadas por actores maliciosos para comprometer la integridad, disponibilidad y confidencialidad del sistema. Además, la presencia de estas librerías obsoletas puede facilitar vectores de ataque como ejecución de código malicioso, manipulación de datos, escalamiento de privilegios o explotación de fallos conocidos, representando una exposición significativa para la seguridad de la aplicación y su entorno operativo.

Específicamente, se documentaron riesgos asociados a CVE-2021-21252 en jQuery y CVE-2025-13465 en Lodash.

Para sistematizar esta evaluación, se elaboró la Tabla 3.4 Matriz de vulnerabilidades en componentes de terceros, donde se detalla el estado de cada componente analizado y su nivel de riesgo asociado.

Tabla 3.4 Matriz de vulnerabilidades en componentes de terceros

Librería	Versión	Estado	Riesgo Potencial
pdfmake	v0.1.5	🔴 Crítico	Obsoleta (2014). Riesgo de XSS y denegación de servicio.
jQuery Validation	v1.17.0	🔴 Crítico	ReDoS (CVE-2021-21252).
Lodash	4.17.21	🔴 Crítico	Ejecución remota de código (RCE) mediante la manipulación de prototipos (Prototype Pollution).
Select2	4.1.0	🟡Medio	Posible XSS si no se sanitizan los resultados de búsqueda.
jQuery	v3.6.1	🟡 Bajo	Estable, pero existen versiones (3.7+) que parchan errores de lógica.
JSZip	v3.10.1	✅Seguro	Versión reciente. Libre de los CVEs críticos de "Prototype Pollution".
Bootstrap	v5.3.0	✅Seguro	Versión moderna y estable.

DataTables	1.12.1	✅Seguro	Relativamente reciente y bien mantenida.

A04 Fallas Criptográficas – [Estatus: No Cumple]:

Se realizó un análisis estático de seguridad (SAST) utilizando la herramienta Horusec, cuyos resultados fueron procesados en un reporte HTML mostrado en la Figura 3.7 Analisis estatico con Horusec, detallado a partir de un archivo JSON.

Esta auditoría identificó 580 posibles vulnerabilidades, indicando el archivo y la línea exacta de código donde se localiza cada debilidad.

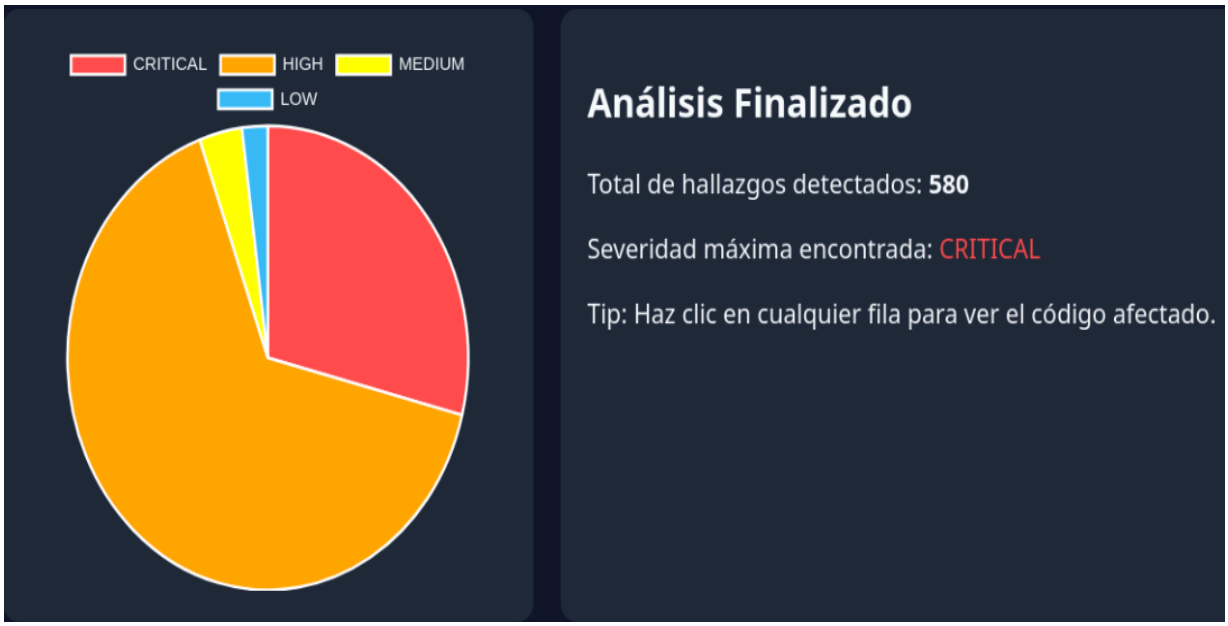


Figura 3.7 Analisis estatico con Horusec

El hallazgo de mayor severidad ha sido la presencia de credenciales en texto plano, incluyendo contraseñas de bases de datos, llaves de API y Secret Keys de servicios en la nube (AWS y Azure) integradas directamente en el código fuente (hardcoded).

Adicionalmente, se detectó que el sistema permite la creación y uso de contraseñas con un mínimo de seis caracteres, una política de seguridad débil que facilita ataques de fuerza bruta y compromete el acceso a los módulos de Inteligencia Empresarial de la plataforma.

A05 Inyección – [Estatus: Cumple]:

Para evaluar la resistencia de la plataforma ante vulnerabilidades de inyección de código, se ejecutó una auditoría exhaustiva en tres niveles. En primer lugar, se utilizó la herramienta sqlmap, un motor especializado en la detección y explotación automática de fallas de inyección SQL, sobre los parámetros de entrada del formulario de inicio de sesión y las barras de búsqueda, aplicando técnicas de inyección basadas en tiempo y booleanos. El motor de base de datos no reveló información, confirmando una correcta parametrización de las consultas en el backend.

Posteriormente, se realizaron pruebas de Inyección HTML (HTMLi) y Cross-Site Scripting (XSS) básico mediante la inserción manual de etiquetas como <u> (para subrayado de texto) y <script>alert(1)</script> en los campos de registro de la plataforma como lo muestra la Figura 3.8 Pruebas de ataques HTMLi y XSS básico. El sistema neutralizó estas entradas, impidiendo que el navegador las interpretara como código ejecutable.

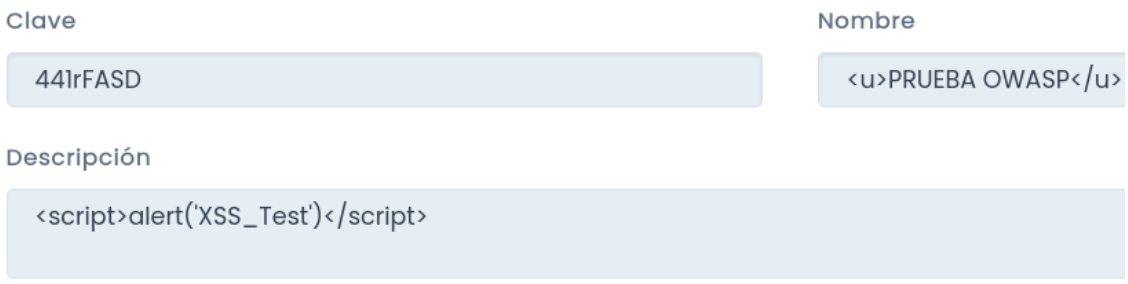


Figura 3.8 Pruebas de ataques HTMLi y XSS básico

Los resultados negativos en estos ataques confirmaron que Andrómeda implementa una robusta higiene o sanitización de datos de salida y que las cookies de sesión cuentan con el atributo HttpOnly el cual se puede confirmar en la Figura 3.9 Análisis de seguridad en las cookies de sesión, lo que impide que scripts maliciosos accedan a los tokens de identidad del usuario.

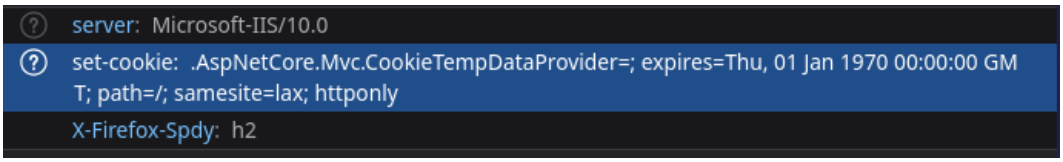


Figura 3.9 Análisis de seguridad en las cookies de sesión

A06 Diseño Inseguro – [Estatus: No Cumple]:

Se identificó una vulnerabilidad de diseño relacionada con la persistencia de datos en el lado del cliente tras la finalización de la sesión. Durante las pruebas manuales, se observó que, al cerrar sesión formalmente, el navegador no limpia de forma automática la memoria caché de las páginas visitadas.

Como evidencia de este fallo, se comprobó que un usuario puede utilizar el historial de navegación para regresar a pantallas de administración previamente consultadas. Aunque el sistema deniega nuevas peticiones al servidor como se puede ver en la Figura 3.10 Acceso denegado sin ninguna sesión, la información confidencial (gráficas y datos sensibles) permanece visible en el monitor. Este hallazgo demuestra la ausencia de cabeceras de control de caché (Cache-Control: no-store) y la falta de un filtro de autenticación que invalide la visualización de contenido local post-sesión.



Figura 3.10 Acceso denegado sin ninguna sesión

A07 Fallas de Autenticación – [Estatus: No Cumple]:

Se llevaron a cabo pruebas de identificación simultánea para validar la gestión de sesiones concurrentes. Utilizando navegadores con motores distintos (Zen Browser y Chromium), se inició sesión con las mismas credenciales de forma paralela. El sistema permitió la coexistencia de ambas sesiones sin emitir alertas ni invalidar el acceso previo.

Esta vulnerabilidad se agrava al considerar que la plataforma permite el uso de contraseñas de solo seis caracteres como mínimo. La combinación de una política de contraseñas débil y la capacidad de mantener sesiones ilimitadas activas incrementa exponencialmente el riesgo de que un atacante mantenga un acceso persistente y desapercibido tras comprometer una cuenta.

A08 Fallas de Integridad de Software y Datos – [Estatus: Cumple]:

En el módulo de carga de información de la plataforma, se realizaron pruebas de estrés para intentar romper la integridad de los datos procesados. Se intentaron cargar archivos con extensiones alteradas y documentos de gran tamaño, así como

tablas de Excel que contenían errores lógicos (campos con ####) o comandos diseñados para ejecutarse en el símbolo del sistema (CMD).

La plataforma demostró una validación estricta mostrando un mensaje de error en la pantalla como se muestra en la Figura 3.11 Validación estricta de archivos xlsx, procesando únicamente archivos con la extensión .xlsx y pdf que cumplieran con la estructura de datos previamente definida. Cualquier intento de procesar contenido malicioso o formatos no autorizados termino siendo rechazado por el motor de validación de Andrómeda, asegurando la integridad de la información.



Figura 3.11 Validación estricta de archivos xlsx

A09 Registro y Alertas – [Estatus: Pendiente]:

Se simuló un ataque de fuerza bruta mediante intentos de login fallidos. Se confirmó que, al alcanzar el sexto intento erróneo, el sistema activa automáticamente un bloqueo de acceso vinculado a la identidad del usuario, el cual tiene una duración de 24 horas.

A pesar de la efectividad del bloqueo, este punto se mantiene con estatus de pendiente debido a que, desde la perspectiva del auditor, no se ha podido validar si estos eventos generan alertas automáticas hacia los administradores del sistema o si

los registros (logs) se almacenan en un medio inmutable y centralizado que permita auditorías forenses posteriores a un incidente.

Este punto debe ser verificado y escalado al departamento encargado de la seguridad a nivel institucional, ya que son los responsables de los servidores.

A10 Manejo de Excepciones – [Estatus: Cumple]:

Para evaluar la resiliencia del sistema ante datos inesperados, se empleó la técnica de fuzzing —procedimiento automatizado que consiste en enviar datos aleatorios o inválidos para detectar fallos de seguridad— con la herramienta ffuf (Fuzz Faster U Fool) y la interceptación de paquetes con Burp Suite mostrado en la Figura 3.12 Pruebas de fuzzing desde Burp Suite. Durante las pruebas, se alteraron deliberadamente los tipos de datos en las peticiones IP; por ejemplo, se enviaron cadenas de texto ("abc") en campos que esperaban valores numéricos, así como valores fuera de rango (números de 20 dígitos) y fechas inexistentes (2026-13-40).



Figura 3.12 Pruebas de fuzzing desde Burp Suite

A diferencia de lo observado en la fase A02 con los errores lógicos, el manejo de excepciones ante datos malformados resultó robusto. El sistema interceptó las anomalías sin revelar stack traces adicionales ni comprometer la estabilidad del

servicio, demostrando que los filtros de entrada en la API son capaces de gestionar ráfagas de datos inválidos sin fugar información sensible sobre la estructura de la base de datos.

3.3.3 Fase III: Propuesta de Mitigación (Recomendaciones)

Una vez concluido el diagnóstico de seguridad, se procedió a elaborar un plan de remediación integral. Las propuestas de mitigación están diseñadas para fortalecer la postura defensiva de la plataforma Andrómeda, priorizando la corrección de fallas que comprometen la confidencialidad de los datos institucionales. Las recomendaciones técnicas se presentan a continuación, clasificadas según el estándar OWASP 2025:

Mitigación para A01 – Control de Acceso Roto:

Se recomienda la implementación de mecanismos de autenticación robustos para todas las interfaces de programación de aplicaciones (APIs). Es imperativo restringir el acceso a los endpoints mediante el uso de tokens de seguridad (como JWT o OAuth2), asegurando que ninguna API sea accesible de forma directa sin una validación previa de la identidad y los permisos del solicitante.

Mitigación para A02 – Configuración Incorrecta:

Ofuscación del Servidor y Gestión de Parches: Se recomienda modificar la configuración del servidor IIS 10.0 para suprimir la exposición del nombre del sistema operativo y su versión en los encabezados de respuesta HTTP (Server y X-Powered-By). Esto se puede realizar mediante la edición de las reglas en el panel de administración de IIS o a través del archivo web.config, impidiendo que un atacante identifique la tecnología base. Asimismo, se recomienda ejecutar un ciclo de actualización de parches de seguridad del sistema operativo para mitigar vulnerabilidades en el puerto 445 (SMB), asegurando que el servidor no sea

susceptible a exploits de ejecución remota de código como los utilizados en ataques tipo Ransomware.

Implementación de Content Security Policy (CSP): Se debe configurar el encabezado CSP, el cual actúa como una capa de seguridad adicional que permite a los administradores restringir los recursos (scripts, imágenes, videos) que el navegador tiene permitido cargar. La implementación de una política CSP robusta mitiga de forma efectiva ataques de Cross-Site Scripting (XSS), Clickjacking e Inyección de datos, al prohibir la ejecución de scripts no autorizados y restringir el origen de los marcos (frames) y dominios de confianza, evitando que la plataforma sea embebida en sitios maliciosos.

Gestión Segura de Errores y Excepciones: Para evitar la fuga de información técnica, se propone sustituir los mensajes de error predeterminados de .NET y C# por páginas de error personalizadas y genéricas orientadas al usuario final. Es fundamental configurar el entorno de producción para que los Stack Traces (rastreos de pila) sean capturados únicamente en los logs internos del servidor y nunca se envíen al cliente como se muestran en la Figura 3.13 Mensaje de error .NET 8 desde el login y Figura 3.14 Mensaje de error C# desde Andrómeda.

Esto garantiza que las rutas de directorios, nombres de métodos y la lógica interna del backend permanezcan ocultas, eliminando las pistas técnicas que permiten a un atacante comprender la estructura interna de las APIs y el sistema de archivos del servidor.



Figura 3.13 Mensaje de error .NET 8 desde el login

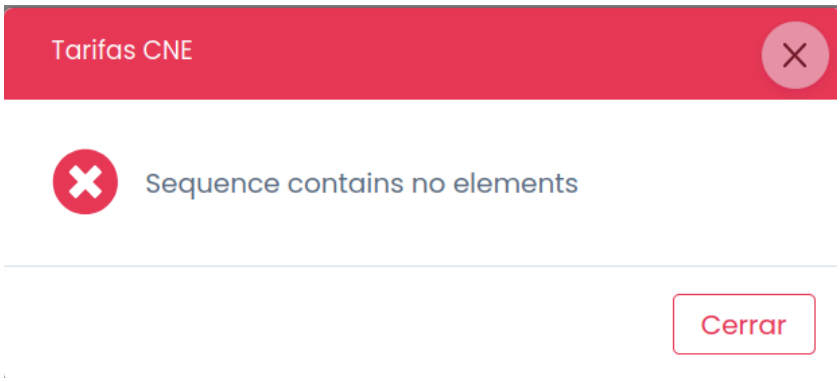


Figura 3.14 Mensaje de error C# desde Andrómeda

Mitigación para A03 – Fallas en la Cadena de Suministro:

Se sugiere establecer un ciclo de gestión de parches para los componentes de terceros. Se debe proceder con la actualización inmediata de las librerías jQuery Validation, pdfmake y lodash a sus versiones estables más recientes que no presenten vulnerabilidades conocidas (CVE). En caso de que la actualización rompa la compatibilidad, se recomienda la sustitución por componentes modernos.

Mitigación para A04 – Fallas Criptográficas:

La recomendación principal consiste en la eliminación total de secretos y credenciales embebidas en el código fuente. Se propone la migración hacia el uso de variables de entorno protegidas o servicios de gestión de secretos (como Azure Key Vault o AWS Secrets Manager). Asimismo, se debe actualizar la lógica de validación de identidad para exigir contraseñas con una longitud mínima de 10 caracteres, integrando requisitos de complejidad (alfanuméricos y caracteres especiales).

Mitigación para A05 – Inyección:

Dado que la plataforma cumple con este control, se recomienda mantener las políticas actuales de parametrización de consultas y la codificación de salida de datos. Se sugiere integrar estas prácticas dentro del manual de desarrollo seguro para prevenir la introducción de nuevas vulnerabilidades durante futuras actualizaciones.

Mitigación para A06 – Diseño Inseguro:

Para evitar la persistencia de datos en el historial del navegador, se propone la implementación de un filtro de autenticación global que asegure la invalidación total de la sesión en el servidor al momento del cierre. Complementariamente, se deben configurar las cabeceras de respuesta HTTP Cache-Control: no-store, no-cache, must-revalidate para impedir que el navegador almacene contenido sensible en el disco local o la memoria caché.

Mitigación para A07 – Fallas de Autenticación:

Se recomienda modificar el motor de gestión de identidades para limitar el número de sesiones activas por usuario. La implementación de un control de concurrencia

permitirá invalidar sesiones previas de forma automática o notificar al usuario sobre accesos simultáneos desde diferentes dispositivos o navegadores, reduciendo la ventana de oportunidad para ataques de secuestro de sesión.

Mitigación para A08 – Fallas de Integridad:

Se propone elevar el estándar de validación de archivos. Además de verificar la extensión .xlsx, se recomienda integrar motores de escaneo que validen la integridad interna de los documentos, asegurando que no contengan macros maliciosas, fórmulas de ejecución remota de código o scripts embebidos que pudieran comprometer el servidor de aplicaciones.

Mitigación para A09 – Registro y Alertas:

Para pasar del estado pendiente a cumplimiento, se recomienda la centralización de los registros de auditoría en un servidor de logs inmutable. Es fundamental que eventos críticos, como el bloqueo de una dirección IP tras múltiples intentos fallidos, generen alertas automáticas en tiempo real hacia los administradores para permitir una respuesta proactiva ante incidentes. Estas alertas pueden ser registradas en logs para identificar causas y evitar futuros ataques.

Mitigación para A10 – Manejo de Excepciones:

Se sugiere continuar con el programa de pruebas de estrés y fuzzing periódico como parte del ciclo de vida de desarrollo de software (SDLC). La resiliencia observada debe mantenerse mediante auditorías recurrentes que validen que los nuevos módulos de la API conserven la capacidad de gestionar datos malformados sin comprometer la estabilidad del sistema.

3.3.4 Fase IV: Reevaluación y Resultados de Mitigación

Tras presentar los hallazgos al equipo de desarrollo, se realizó una segunda ronda de pruebas para validar la implementación de las correcciones. Debido a las restricciones de tiempo del proyecto, se priorizó la resolución de las vulnerabilidades más críticas.

Se confirmó la mitigación exitosa de los riesgos A01, A03, A04 y A09, logrando la eliminación de secretos en el código fuente, el reforzamiento de los filtros de inyección y la optimización del monitoreo de intentos de acceso. Las vulnerabilidades restantes, relacionadas principalmente con la actualización de dependencias de terceros y cambios profundos en la arquitectura de sesiones, quedaron documentadas en la matriz de riesgo final como pendientes para futuras iteraciones de mantenimiento, asegurando que el equipo del INEEL tenga una ruta clara para su resolución.

3.4 Control

La fase de control permitió supervisar el progreso de la auditoría de seguridad y asegurar la alineación entre los hallazgos técnicos y las expectativas de la Gerencia de Tecnologías de la Información del INEEL. En esta etapa se gestionaron las comunicaciones, los cambios en el cronograma y la mitigación activa de riesgos operativos.

3.4.1 Reuniones de Seguimiento y Presentación de Avances

El control del proyecto se basó en un esquema de comunicación constante con el equipo de desarrolladores de la plataforma Andrómeda. Se llevaron a cabo un total

de cinco reuniones técnicas de seguimiento, estructuradas para validar cada fase de la auditoría:

1. **Presentación de Fase I:** Validación del alcance y aprobación del Project Charter.
2. **Reporte de Análisis Estático:** Entrega de los hallazgos de Horusec y discusión sobre secretos embebidos.
3. **Resultados de Análisis Dinámico:** Demostración de vulnerabilidades de sesión y fallas en APIs.
4. **Sesión de Seguimiento:** Presentación de nuevos hallazgos críticos detectados tras la reconfiguración de pruebas de penetración.
5. **Cierre y Evaluación Final:** Sesión programada para validar la matriz de cumplimiento final y la entrega de la guía de mitigación.

3.4.2 Seguimiento de Actividades

Se realizó un monitoreo continuo del cronograma de actividades mediante el diagrama de Gantt. Durante el mes de abril, se identificó una desviación en la planeación original: inicialmente, este periodo estaba destinado exclusivamente a la validación de recomendaciones; sin embargo, debido a la profundidad del análisis dinámico, se integró una fase adicional de presentación de hallazgos.

A pesar de este cambio, el control de tiempos permitió reajustar las actividades de cierre sin comprometer la fecha final del 17 de abril. Esta flexibilidad en la gestión aseguró que el equipo de desarrollo recibiera la información más reciente antes de proceder con la evaluación final de la matriz OWASP.

3.5 Cierre

La fase de cierre representa la culminación formal del proyecto de auditoría. En esta etapa se consolidaron los resultados obtenidos y se realizó la transferencia de

conocimiento hacia el equipo de desarrollo del INEEL, asegurando que la institución cuente con las herramientas necesarias para mantener la integridad de la plataforma Andrómeda.

3.5.1 Finalización y Entrega de Resultados

El cierre administrativo inició tras la validación de las propuestas de mitigación. Se llevó a cabo una sesión final con el M.C. Omar Hernández López, donde se presentaron los hallazgos definitivos y el estado actual de la matriz de cumplimiento OWASP. Durante esta etapa, se enfatizó en aquellas vulnerabilidades que, debido a su complejidad técnica, requieren un seguimiento a mediano plazo por parte del equipo de infraestructura del instituto.

3.5.2 Relación de Entregables Técnicos

Como parte del cierre formal, se hizo entrega de un paquete documental y técnico que respalda cada fase de la auditoría. Los entregables proporcionados al cliente incluyen:

- **Reporte de Tráfico y Alertas (OWASP ZAP):** Documentación detallada de las peticiones HTTP/HTTPS interceptadas, identificando los vectores de ataque dinámicos y las alertas de seguridad generadas durante el escaneo de la plataforma.
- **Reporte Maestro de Seguridad Estática (Horusec):** Un tablero visual en formato HTML derivado del análisis de los archivos JSON de Horusec. Este reporte permite al equipo de desarrollo localizar con precisión las 580 vulnerabilidades identificadas, indicando el archivo, la línea de código y la severidad del hallazgo.
- **Reporte de Análisis de Composición (Dependency-check):** Inventario técnico de las librerías de terceros utilizadas en Andrómeda, detallando los CVEs

(Vulnerabilidades y Exposiciones Comunes) asociados a los componentes desactualizados detectados.

- **Compendio de Transferencia de Conocimiento:** Un conjunto de las cuatro presentaciones ejecutivas utilizadas durante las reuniones de seguimiento, las cuales sirven como guía técnica para que los desarrolladores comprendan los métodos de explotación utilizados.
- **Matriz de Cumplimiento OWASP 2025:** Documento estratégico que resume el estado final de cumplimiento de la plataforma frente a los diez riesgos más críticos del estándar, incluyendo las recomendaciones de mitigación sugeridas.

CAPÍTULO 4. CONCLUSIONES

4.1 Cumplimiento de objetivos

El objetivo general del proyecto se cumplió satisfactoriamente al realizar una evaluación técnica integral bajo el marco de referencia OWASP 2025. Se logró identificar la superficie de ataque de la plataforma, permitiendo al instituto transitar de una gestión reactiva a una postura proactiva en ciberseguridad.

Respecto a los objetivos específicos, se alcanzó el 100% de la meta en la fase de diagnóstico mediante el uso de herramientas de grado profesional como Horusec y OWASP ZAP. La documentación de los 580 hallazgos estáticos y la identificación de riesgos en las APIs cumplieron con la expectativa de profundidad técnica requerida. Asimismo, la fase de mitigación permitió identificar vulnerabilidades críticas relacionadas con la exposición de secretos (A04) y el control de acceso (A01), demostrando que el proyecto no solo ha sido un ejercicio de diagnóstico, sino un proceso de mejora continua de la infraestructura institucional.

4.2 Resultados

El resultado principal es el fortalecimiento del ciclo de vida de desarrollo de software (SDLC) de Andrómeda. Tras la reevaluación en la Fase IV del desarrollo, se confirmó la reducción significativa del riesgo tecnológico en cuatro de las categorías más críticas del OWASP Top 10.

A nivel documental, se entrega una infraestructura de reporteo inaudita en la gerencia: una matriz de cumplimiento dinámica y reportes visuales en HTML que facilitan la corrección de errores en tiempo récord. Aunque existen vulnerabilidades pendientes de resolución (como la gestión de sesiones concurrentes y la

actualización de dependencias obsoletas), la plataforma cuenta ahora con una hoja de ruta clara para su remediación. La lista de recomendaciones y la guía para la identificación de vulnerabilidades, permitirá desarrollar sistemas de inteligencia empresarial más resilientes, capaces de proteger la integridad de la información y los datos estratégicos del sector energético que procesa el INEEL al desarrollar sistemas de información.

4.3 Contribuciones

La estadía generó beneficios bidireccionales de alto impacto. Para el INEEL, la principal contribución fue la transferencia de conocimiento técnico y la implementación de una metodología de auditoría estandarizada. La identificación de brechas en la configuración de servidores (puertos expuestos y falta de CSP) permitió al equipo de TI identificar configuraciones que habían pasado inadvertidas, elevando el estándar de seguridad de toda la red perimetral vinculada a Andrómeda.

Desde la perspectiva profesional, este proyecto contribuyó al desarrollo de competencias avanzadas en el uso de distribuciones especializadas como BlackArch Linux y el dominio de herramientas de interceptación de tráfico. La capacidad de traducir reportes técnicos complejos (archivos JSON de 580 hallazgos) en presentaciones ejecutivas para la toma de decisiones gerenciales representa una de las mayores ganancias en habilidades blandas y técnicas. En conclusión, la estadía consolidó la formación como Ingeniero en Redes Inteligentes y Ciberseguridad, aplicando conocimientos de vanguardia en un entorno real de alta exigencia institucional.

REFERENCIAS

Grupo de trabajo de ingeniería de Internet (IETF). (2018). *The Transport Layer Security (TLS).* RFC 8446.

Herzog, P. I. (2003). *The Open Source Security Testing Methodology Manual.* OSSTMM 2.1.

Instituto Nacional de Estandares y Tecnologías (NIST). (2004). *Standards for Security Categorization of Federal Information and Information Systems.* FIPS PUB 199.

Lyon, G. (1 de Septiembre de 1997). *Chapter 15. Nmap Reference Guide*. Obtenido de Nmap: the Network Mapper: https://nmap.org/book/man.html#man-description

Mozilla. (22 de Diciembre de 2025). *HTTP: Hypertext Transfer Protocol*. Obtenido de MDN - MDN Web Docs: https://developer.mozilla.org/en-US/docs/Web/HTTP

Organización Internacional de Normalización (ISO). (1994). *Open Systems Interconnection.* ISO/IEC 7498.

OWASP. (Septiembre de 2025). *OWASP Foundation*. Obtenido de the Open Source Foundation for Application Security: owasp.org

OWASP Foundation. (14 de Mayo de 2010). *Getting Started*. Obtenido de ZAP: https://www.zaproxy.org/getting-started/

OWASP Top 10. (Septiembre de 2025). Obtenido de OWASP: https://owasp.org/Top10/2025/

PortSwigger. (1 de Enero de 2006). *Burp - Web Application Security*. Obtenido de PortSwigger: https://portswigger.net/burp

PortSwigger. (15 de Enero de 2024). *Community Edition*. Obtenido de Burp Suite: https://portswigger.net/burp/communitydownload

SANS Institute. (30 de Junio de 2025). *Securing the Data Analytics Pipeline: Best Practices for Business Intelligence.* Obtenido de Cybersecurity Training: https://www.sans.org/webcasts/data-analytics-continuous-risk-management

Scarfone, K. &. (2008). *Technical Guide to Information Security Testing and Assessment.* P. NIST Special Publication 800-115.

Sommerville, I. (2011). *Software Engineering (9th ed.).*

Zup Innovation. (20 de Julio de 2020). *Horusec*. Obtenido de Github: https://github.com/ZupIT/horusec

ANEXOS

ANEXO A. PROJECT CHARTER

Project Charter

Proyecto	PCAMDO	Pruebas de cumplimiento y alineación al marco de referencia de desarrollo seguro OWASP en la plataforma Andrómeda.
Cliente		M.C Liliana Paz Argotte Ramos

Planteamiento del Problema
La plataforma Andrómeda, desarrollada por el INEEL para la CFE, es una herramienta de Inteligencia Empresarial (BI) crítica que maneja modelos de escenarios y pronósticos económicos nacionales. A pesar de su robustez funcional, el sistema carece de una evaluación de seguridad formal bajo estándares internacionales. Durante las fases de prueba preliminares, se han detectado riesgos de alta prioridad, como credenciales de servicios de nube (AWS/Azure) expuestas en el código y el uso de librerías obsoletas, lo que vulnera la integridad de la información estratégica de la CFE.

Justificación
La ejecución de este proyecto es indispensable para garantizar la propiedad intelectual y la confidencialidad de los datos del sector energético. La alineación con el estándar OWASP permite al INEEL realizar la transición de sistemas hacia un modelo de desarrollo seguro, mitigando vectores de ataque antes de la puesta en producción. Agregar seguridad al sistema Andrómeda no es solo una mejora técnica, sino un requisito de cumplimiento para proteger la toma de decisiones económicas de la Comisión Federal de Electricidad.

Objetivo General
Evaluar y fortalecer la postura de ciberseguridad de la plataforma Andrómeda mediante ejecución de pruebas de hacking ético alineadas al OWASP Top 10.

Entregables
Matriz de Cumplimiento OWASP.
Reporte de Vulnerabilidades SAST/DAST.
Guía de Mitigación y Buenas Prácticas.
Reporte Final de Estadía.

Requerimientos
Funcionales
Realizar un escaneo estático de código fuente (SAST) para detectar secretos y credenciales embebidas.
Ejecutar pruebas dinámicas (DAST) sobre las APIs de integración para validar el manejo de sesiones.
Evaluar la configuración de cabeceras de seguridad en el servidor de la plataforma.
Documentar cada vulnerabilidad siguiendo el estándar de severidad CVSS (Common Vulnerability Scoring System).
No Funcionales
Toda la información técnica de Andrómeda debe manejarse bajo el acuerdo de confidencialidad INEEL-CFE.
La tasa de falsos positivos en el reporte final debe ser mínima mediante la validación manual con la herramienta Burp Suite.
El reporte debe cumplir con el formato Arial 12, interlineado 1.5 y 3 cm de margen izquierdo.

Líder de Proyecto
Robbie Daniel Mejía Arroyo

Project Charter

Proyecto	PCAMDO	Pruebas de cumplimiento y alineación al marco de referencia de desarrollo seguro OWASP en la plataforma Andrómeda.
Cliente		M.C Liliana Paz Argotte Ramos

Fecha de Inicio	19/01/26	**Fecha de Fin**	17/04/26

Cronograma de Hitos	
Evento	**Fecha**
Mes 1: Participar en sesiones de introducción a la plataforma Andrómeda y revisión del marco OWASP top 10.	19/01/26
Mes 2: Identificar riesgos de seguridad en módulos críticos de la plataforma Andrómeda.	01/02/26
Mes 3: Establecer recomendaciones sobre vulnerabilidades identificadas.	01/03/26
Mes 4: Elaborar plan de pruebas sobre las recomendaciones realizadas.	06/04/26

Riesgos
Falsos positivos generados por herramientas automáticas que requieran tiempo excesivo de validación manual.
Degradación accidental de la disponibilidad del servidor de Andrómeda o saturación de reglas en el Firewall perimetral debido a la intensidad de las ráfagas en las pruebas de Fuzzing o escaneos dinámicos.
Cambios en la arquitectura de Andrómeda durante la auditoría que invaliden pruebas previas.

Supuestos
Se asume que el INEEL proporcionará el código fuente completo de la plataforma a evaluar.
Se asume que las herramientas de código abierto (Horusec, ZAP) son suficientes para los objetivos del proyecto.
Se cuenta con la disponibilidad del Asesor Empresarial para sesiones de revisión técnica.
Restricciones o Limitaciones
No se realizarán ataques masivos de denegación de servicio (DoS) para no interrumpir el flujo de desarrollo.
Las pruebas se limitan exclusivamente al servidor de desarrollo (Dev), sin tocar producción.
El auditor no realizará la programación de las correcciones, solo entregará la guía con las recomendaciones.

Costo		

Líder de Proyecto	**Sponsor**	**Cliente**
Robbie Daniel Mejía Arroyo	M.T.I. Verónica Sánchez López	M.C Liliana Paz Argotte Ramos
Firma	Firma	Firma

ANEXO B. MATRIZ DE ANÁLISIS DE RIESGOS

ID	Riesgo Identificado	Descripción	Impacto	Probabilidad	Nivel de Riesgo	Medidas de Mitigación
R1	Saturación del firewall o servidor	Posible sobrecarga del firewall o del servidor de aplicaciones debido a pruebas de alta concurrencia (fuzzing).	Alto	Media	Alto	Limitación de tráfico en herramientas de escaneo y pruebas en horarios de baja carga.
R2	Indisponibilidad de la herramienta Andrómeda	Riesgo de no contar con acceso a la herramienta en el servidor de desarrollo o fallas en la conectividad a internet.	Medio	Media	Medio	Instalación en entorno local y pruebas dinámicas en el servidor de desarrollo.

ANEXO C. CRONOGRAMA DE ACTIVIDADES

PROGRAMA DE ACTIVIDADES	
Nombre del becario:	**Robbie Daniel Mejía Arroyo**
Título del tema de la estancia:	Apoyo en el análisis y fortalecimiento de la ciberseguridad de la plataforma Andrómeda, mediante la detección de vulnerabilidades con OWASP.
Inicio:	Jan-2026
Término:	Apr-2026

CALENDARIO

Actividad	Meses del año 2026																			
	enero				febrero				marzo				abril				mayo			
1. Participar en sesiones de introducción a la plataforma Andrómeda y revisión del marco OWASP top 10.			■	■	■															
2. Identificar riesgos de seguridad en módulos críticos de la plataforma Andrómeda.					■	■	■	■												
3. Establecer recomendaciones sobre vulnerabilidades identificadas.									■	■	■	■								
4. Elaborar plan de pruebas sobre las recomendaciones realizadas.													■	■	■	■				
5. Documentación.					■				■				■				■	■		